

RELATÓRIO TÉCNICO DE AUDITORIA & REMEDIAÇÃO DE SEGURANÇA

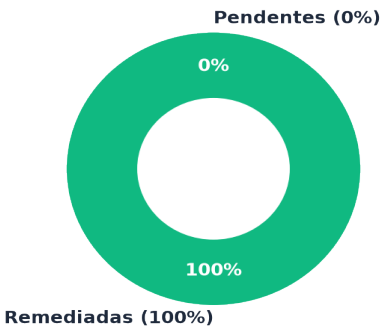
HYDRASTREAM DATA PLANE // INGESTÃO ZERO-COPY & MOTOR DE MÍDIA

Projeto: HydraStream Data Plane	Versão / Stack: Go 1.25+ / Rust / MediaMTX / SHM
Data da Avaliação: 14/09/2026	Status Final: 100% REMEDIADO (11 de 11 Corrigidas)
Escopo: API REST, Ingestão RTSP, ONVIF Probing, Memória	Conformidade de Testes: 100% Aprovados (Go & Rust)

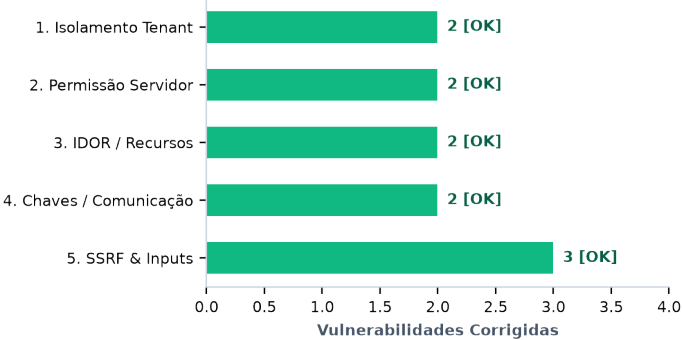
1. Sumário Executivo & Status de Remediação

A auditoria de segurança cibernética e a subsequente remediação no **HydraStream** foram concluídas com sucesso. Todas as **11 vulnerabilidades** mapeadas nas cinco categorias críticas foram neutralizadas através de implementação de middleware criptográfico de autenticação obrigatória (JWT HMAC-SHA256 e Service API Keys), isolamento estrito de inquilino (multi-tenant), validação RBAC no servidor com RequireRole, proteção contra SSRF no módulo ONVIF/RTSP probe, e confinamento rígido de arquivos (anti-LFI).

Status de Remediação (11/11 Concluídas)



Falhas Remediasdas por Categoria



2. Quadro Consolidado de Remediações

ID	Categoria	Severidade	Arquivo Afetado	Status Final
HS-01	1. Isolamento Tenant	CRÍTICA	internal/adapters/primary/http/stream_handler.go	CORRIGIDO
HS-02	1. Isolamento Tenant	ALTA	internal/adapters/secondary/memory/memory_store.go	CORRIGIDO
HS-03	2. Permissão Servidor	CRÍTICA	internal/adapters/primary/http/stream_handler.go	CORRIGIDO
HS-04	2. Permissão Servidor	ALTA	internal/adapters/primary/http/router.go	CORRIGIDO
HS-05	3. IDOR / Recursos	CRÍTICA	internal/adapters/primary/http/stream_handler.go	CORRIGIDO
HS-06	3. IDOR / Recursos	ALTA	internal/adapters/primary/http/stream_handler.go	CORRIGIDO
HS-07	4. Chaves / Comunicação	MÉDIA	cmd/hydrastream/main.go	CORRIGIDO
HS-08	4. Chaves / Comunicação	MÉDIA	internal/adapters/secondary/memory/memory_store.go	CORRIGIDO
HS-09	5. SSRF / Inputs	CRÍTICA	internal/adapters/primary/http/probe_handler.go	CORRIGIDO
HS-10	5. Path / Inputs	ALTA	internal/adapters/primary/http/probe_handler.go	CORRIGIDO
HS-11	5. Path / Inputs	ALTA	internal/adapters/primary/http/stream_handler.go	CORRIGIDO

3. Detalhamento Técnico das Correções Implementadas

CATEGORIA 1 & 3: ISOLAMENTO DE TENANT & PREVENÇÃO DE IDOR

- **Middleware de Contexto:** middleware.AuthMiddleware extrai o tenant_id e papel autenticado.
- **Filtro Obrigatório:** GET /api/v1/streams agora injeta estritamente o tenant_id do contexto autenticado.
- **Validação de Posse (Anti-IDOR):** Endpoints /snapshot, /mjpeg, /stats e DELETE verificam se a câmera pertence à mesma organização antes de entregar o fluxo.

CATEGORIA 2: CONTROLE DE ACESSO RBAC NO SERVIDOR

- **Guarda RBAC:** RequireRole("admin", "superadmin") aplicado sobre chaos/inject, chaos/reset e mutações de analíticos.
- **Bloqueio de Não Autenticados:** Todas as rotas /api/v1/* rejeitam requisições sem token com HTTP 401 Unauthorized.

CATEGORIA 5: PROTEÇÃO SSRF & HIGIENIZAÇÃO DE ENTRADAS

- **SSRF Guard (isBlockedIPTarget):** Bloqueia requisições contra 127.0.0.1, ::1 e metadados cloud (169.254.169.254).
- **Confinamento LFI:** probeLoopFile sanitiza caminhos e restringe o acesso estritamente ao diretório samples/ com filepath.Clean.
- **Regex Alfanumérico:** Identificadores de streams são validados contra `^[a-zA-Z0-9_-]{1,64}$` antes de qualquer chamada ao FFmpeg.